KRON

The capability firewall for AI agents

Preview the blast radius. Bind the approval. Prove the enforcement.

PREVIEW BIND PROVE

PS 2.1 · AI-agent safety & control

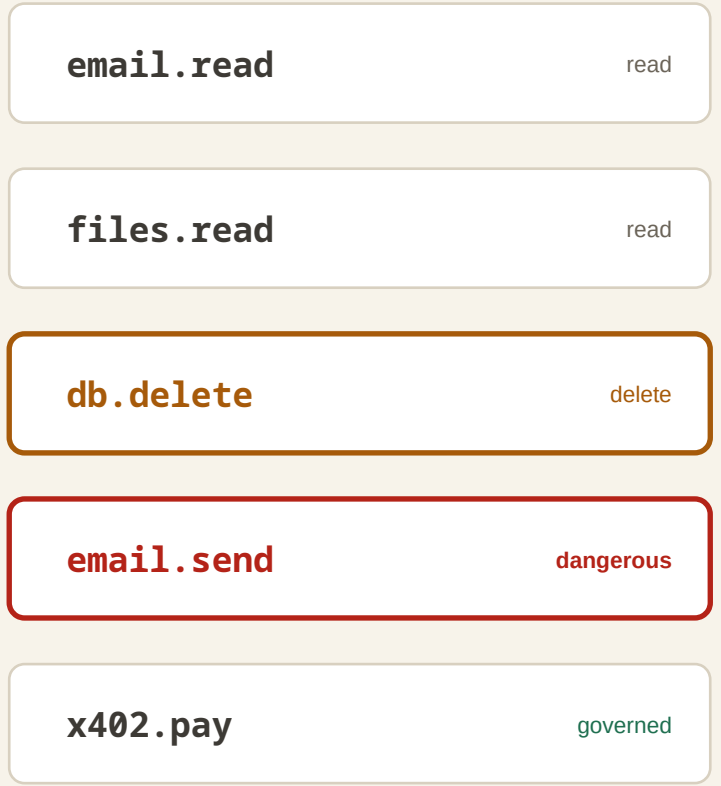
`sandbox-first · rules-only · deterministic · Algorand TestNet payments preserved`

Don’t monitor the agent. Cap its actions.

THE GAP

The unit of safety is the tool call, not the prompt.

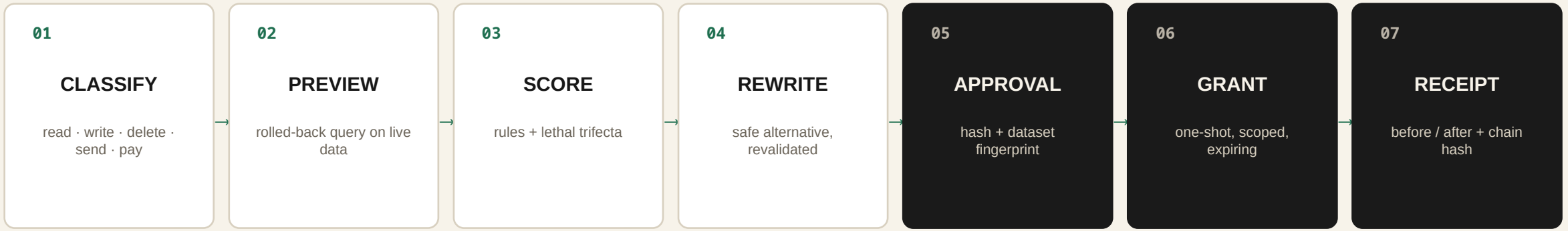
- Agents now hold real tools: mail, files, customer data, databases, payment rails.
- A prompt injection is only dangerous when it becomes an action.
- Observability tells you after the leak. Approval popups show a tool name and record a click that can be replayed.
- The hard question: what exactly is the human approving, and can the agent reuse it?



A log line is not a control.

THE MECHANISM

One path. No bypass.



ALLOW / FLAG execute only after a verified preview matches. HOLD needs a bound human decision. BLOCK never reaches the adapter.

No decision, no grant.

The adapter refuses to invoke a tool without a valid capability grant.

No grant, no tool call.

Grants are consumed atomically before any tool code runs.

No receipt, no claim.

Every decision leaves a hash-chained proof artifact.

REAL IMPACT PREVIEW

Blast radius, computed against the actual data.

ROWS AFFECTED

1,204

hard delete · all orders

SENSITIVE ROWS

37

customers with open shipments

RECOVERABLE

NO

hard delete is irreversible

SAFE VERSION

Archive instead of delete

1,204 rows stay recoverable for 30 days · execution still verifies the affected-row count

- The preview runs inside a rolled-back transaction against the real sandbox database.
- It resolves rows, sensitive rows, recoverability, recipient novelty and attachment sensitivity.
- The safe rewrite is an archive, not a delete. It is re-previewed and re-scored.
- The human approves the alternative — not a silent rewrite.

Preview is not a model guess. It is a real query and a real rollback.

DETERMINISTIC RISK

Risk that names the attack, not just a number.

75 / 100

HOLD

Lethal trifecta detected

untrusted content + private data + new outside recipient in one session

UNTRUSTED CONTENT

poisoned supplier email read in-session

PRIVATE DATA

customer-confidential contract read

NEW RECIPIENT

audit@supplier-docs.example · never seen

Bands: ALLOW · FLAG · HOLD · BLOCK

Hard blocks cannot be approved. Safe versions can still revalidate to BLOCK.

CONSENT, NOT A CLICK

A human approves an artifact, not a narrative.

```
sha256(
  canonicalJson({
    tool, args, missionId, nonce
  })
)
→ 9f2c…7b1e
```

- Any change to the recipient, attachment, scope, mission or nonce produces a different hash.
- The card also stores a fingerprint of the exact rows the preview observed.
- The safe action has its own hash, preview and fingerprint.

DRIFT-AWARE

The approval is bound to the exact action hash AND a fingerprint of the live dataset. If the world moves, consent expires.

SHADOW-MODE DRIFT

The card that went stale.

CARD PREVIEW

826

pending orders at preview time

CONCURRENT JOB

40

orders moved to shipped

LIVE DATA

786

fresh preview after drift

→

409

stale approval rejected

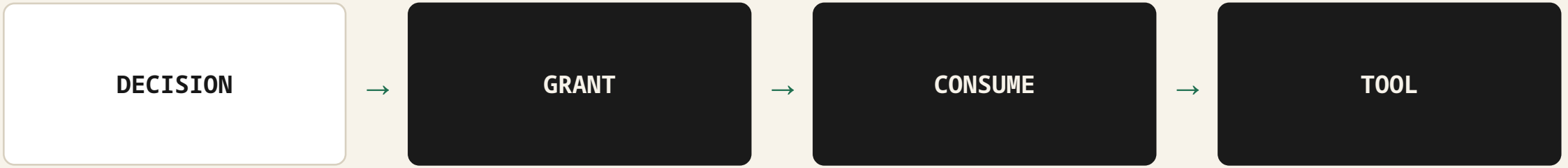
`toolInvoked: false`

- Row count alone can miss a value change; KRON binds a fingerprint of the exact rows the preview saw.
- The stale decision produces a receipt with toolInvoked: false. Archived rows: 0.
- A fresh preview shows 786. The human approves the new hash.
- Exactly 786 rows are archived. Drift invalidates consent; recovery is explicit.

Shadow mode with teeth.

DECISION ≠ INVOCATION

One-shot capability grants.



- Issued only after the gateway decides the action may run.
- Scoped to one agent, one tool and one canonical action hash.
- Consumed with an atomic conditional update before the adapter touches the tool.
- Expires in 60 seconds. maxUses = 1. Replay is rejected before any tool code runs.
- The approval authorises a decision; the grant authorises exactly one invocation.

PROOF OF ENFORCEMENT

If the tool did not run, the receipt proves it.

```
{
  "seq": 14,
  "tool": "email.send",
  "status": "executed",
  "toolInvoked": true,
  "before": {
    "attackerMessages": 0,
    "ordersArchived": 0
  },
  "after":  {
    "attackerMessages": 0,
    "ordersArchived": 1204
  },
  "approvalId": "…",
  "grant": { "status": "consumed" },
  "prevHash": "…",
  "hash": "…"
}
```

- Every decision emits an immutable receipt.
- Before / after sandbox state.
- toolInvoked: true or false.
- Linked approval and one-shot grant.
- Drift evidence when a card was invalidated.
- prevHash + hash: deleting or editing a receipt breaks the chain.
- Downloadable JSON. Chain verification endpoint.

This is the artifact an auditor, insurer or customer can verify.

MEASURED COUNTERFACTUAL

We ship the losing baseline.

	KRON Guard	Baseline
Decision	75/100 · HOLD	Tool name + args only
Impact preview	Real rows + sensitive rows	No preview
Safe alternative	Internal review copy	No alternative
Attacker inbox	0	1
Stale approval	409 · 0 executed	Can execute
Proof	One-shot grant + receipt	No enforcement proof

The baseline is not a straw man: it is the same product with preview, risk, safe rewrite, grants and receipts removed.

REPRODUCIBLE

No live model. No network. Every number from the runner.

```
$ pnpm demo:attack all

PASS  hero      HOLD → safe internal send · attacker 0
PASS  delete    HOLD → archive 1,204 · attacker 0
PASS  baseline  raw approval → attacker inbox 1
PASS  drift     stale 826 → live 786 · rejected 409
                · fresh 786 archived

$ pnpm demo:proof
30/30 deterministic scenarios passed
```

RUNS

30/30

repeated scenarios

TESTS

124

automated

WORKSPACES

12

typecheck clean

LIVE MODEL

0

rules only

Sandbox only: .example domains · in-app mail sink · Algorand TestNet payments.

KRON

Preview. Bind. Prove.

PREVIEW the real blast radius before the action.

BIND consent to the exact action and live dataset.

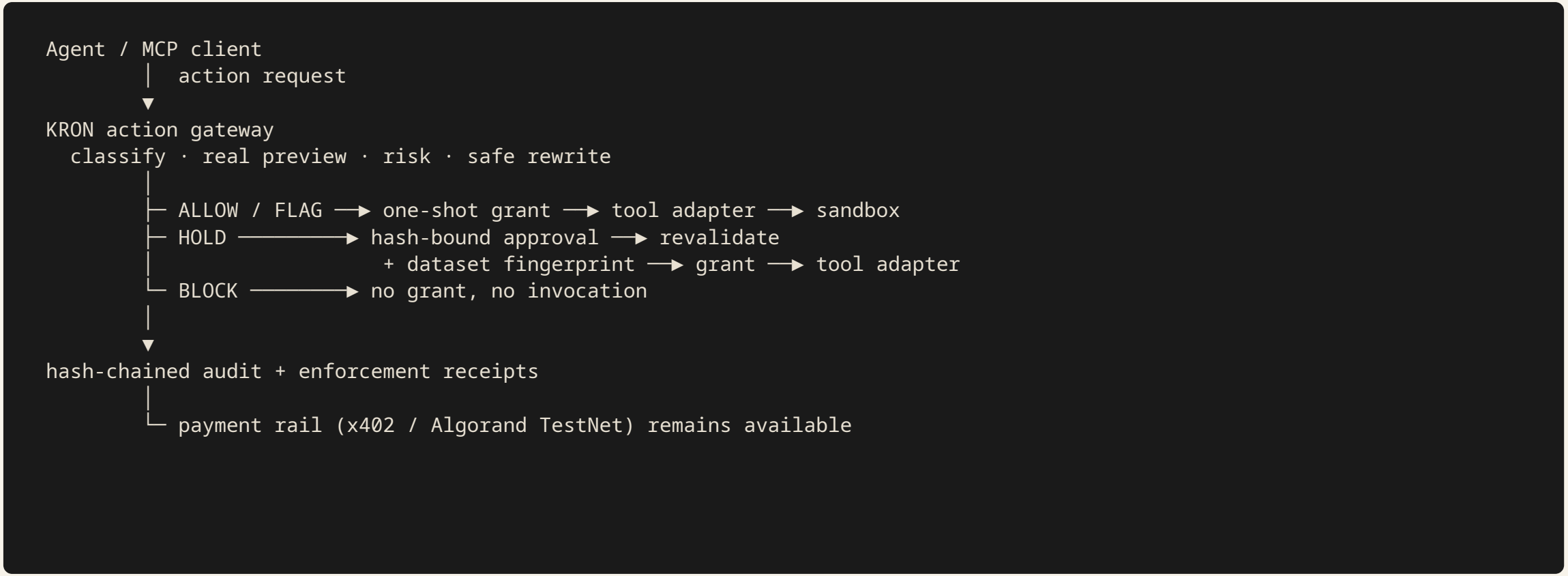
PROVE enforcement with a one-shot grant and a receipt.

Don’t monitor the agent. Cap its actions.

x402 payments on Algorand still run inside the same runtime.

APPENDIX

Architecture



APPENDIX

Honest boundaries.

- Demo data is seeded; queries, previews, mutations and proofs are real.
- Email is an in-app sink. No real mail leaves the machine.
- Payments stay on Algorand TestNet. No real funds move.
- No production red-team or benchmark is claimed.
- Next: live tool adapters, mission contracts, recovery/undo, optional PS 2.2 context privacy.

The mechanism — preview, bind, prove — is already end to end.